Relatório de Modelagem de Ameaças - Banco Box

Proprietário: Grupo DevSecOps Banco Box

Descrição: Modelo com as 20 ameaças STRIDE injetadas e estrutura JSON rigorosamente limpa para passar no validador de esquema do Threat Dragon v2.

Ameaças Identificadas

Título: TM-15 Indisponibilidade total por VM Única
Elemento Afetado: 1.0 Nginx Gateway (tm.Process)
Categoria (STRIDE): Denial of Service
Severidade: High
Status: Open

Descrição: Atacante direciona ataque DDoS volumétrico contra o IP público derrubando todo o ecossistema bancário operando sob um único ponto de falha (uma VM EC2).

Mitigação Proposta: Migrar para Auto Scaling Groups / Kubernetes com WAF na borda (CloudFront/Shield).

Título: TM-01 Força bruta no login
Elemento Afetado: 2.0 auth-service (tm.Process)
Categoria (STRIDE): Spoofing
Severidade: High
Status: Open

Descrição: Fraudador automatiza tentativas de CPF+senha vazados -> acessa conta -> faz Pix para laranja

Mitigação Proposta: Rate limit + MFA + detecção

Título: TM-02 Enumeração de CPFs de clientes ativos
Elemento Afetado: 2.0 auth-service (tm.Process)
Categoria (STRIDE): Information Disclosure
Severidade: Medium
Status: Open

Descrição: Atacante executa script de teste de CPFs em lote no Login coletando mensagens de erro explícitas para mapear e vender lista de correntistas ativos.

Mitigação Proposta: Unificar mensagem para erro genérico: 'CPF ou senha inválidos'.

Título: TM-20 Account Takeover via SIM Swap (MFA SMS)
Elemento Afetado: 2.0 auth-service (tm.Process)
Categoria (STRIDE): Spoofing
Severidade: High
Status: Open

Descrição: Quadrilha realiza SIM Swap de clientes, captura o código SMS de MFA, entra na conta e esvazia o saldo através de transferências Pix noturnas.

Mitigação Proposta: Descontinuar SMS como único fator. Adotar MFA via app nativo (TOTP) ou Push Notification com Number Matching.

Título: TM-03 Burlar limite via flag no cliente
Elemento Afetado: 3.0 pix-service (tm.Process)
Categoria (STRIDE): Tampering
Severidade: High
Status: Open

Descrição: Atacante intercepta o JSON do fluxo do Pix e injeta a flag limite_override=true forçando o desvio de saldos acima do limite diurno/noturno do Bacen.

Mitigação Proposta: Remover o parâmetro do cliente e efetuar a checagem exclusivamente na API de backend.

Título: TM-04 Fraude IDOR/BOLA por conta arbitrária
Elemento Afetado: 3.0 pix-service (tm.Process)
Categoria (STRIDE): Tampering
Severidade: Critical
Status: Open

Descrição: Atacante altera o valor do campo JSON conta_origem na API pública de transferências Pix para debitar e esvaziar fundos de contas de terceiros correntistas.

Mitigação Proposta: Extrair o ID do usuário autenticado estritamente das claims seguras criptografadas do token JWT.

Título: TM-05 Bypass do Antifraude por Saturação
Elemento Afetado: 3.0 pix-service (tm.Process)
Categoria (STRIDE): Denial of Service
Severidade: High
Status: Open

Descrição: Atacante inunda a API de Pix simulando lentidão de processamento, acionando o timeout de 2 segundos para aprovar automaticamente Pix fraudulentos por 'fail open'.

Mitigação Proposta: Alterar o comportamento para 'Fail Close', retendo a transação suspeita sob custódia e gerando alerta.

Título: TM-13 Criação massiva de contas laranjas
Elemento Afetado: 5.0 onboarding-srv (tm.Process)
Categoria (STRIDE): Spoofing
Severidade: High
Status: Open

Descrição: Quadrilha de fraude abre centenas de contas por dia injetando selfies falsas extraídas de deepfakes e fotos estáticas sem prova de vida ativa.

Mitigação Proposta: Integrar SDK nativo de captura biométrica em tempo real com teste de prova de vida (Liveness Detection).

Título: TM-14 Sequestro de conta por dados públicos
Elemento Afetado: 5.0 onboarding-srv (tm.Process)
Categoria (STRIDE): Elevation of Privilege
Severidade: High
Status: Open

Descrição: Golpista altera o celular de recuperação da vítima fornecendo apenas o CPF e o nome da mãe da vítima extraídos de vazamentos públicos da internet.

Mitigação Proposta: Proibir alteração de dados críticos por perguntas estáticas; exigir validação multifator robusta.

Título: TM-18 Repúdio de conta laranja após lavagem
Elemento Afetado: 5.0 onboarding-srv (tm.Process)
Categoria (STRIDE): Repudiation
Severidade: High
Status: Open

Descrição: Membro da Quadrilha abre conta, lava dinheiro via Pix e contesta a abertura alegando 'roubo de identidade'. O banco não tem rastro digital forte para provar autoria.

Mitigação Proposta: Coletar fingerprint do dispositivo (Device ID, IP) e assinar digitalmente o log de consentimento em base WORM.

Título: TM-19 Exaustão financeira em APIs de terceiros
Elemento Afetado: 5.0 onboarding-srv (tm.Process)
Categoria (STRIDE): Denial of Service
Severidade: High
Status: Open

Descrição: Quadrilha automatiza envio de 10.000 aberturas de conta falsas. Backend repassa ao SERPRO, esgotando cota financeira do banco (Economic DoS) e bloqueando clientes.

Mitigação Proposta: Aplicar Rate Limiting rigoroso por IP no Nginx e exigir CAPTCHA/desafio antes de invocar os Bureaus.

Título: TM-11 Fraude contábil indetectável de operador
Elemento Afetado: 4.0 backoffice-api (tm.Process)
Categoria (STRIDE): Repudiation
Severidade: High
Status: Open

Descrição: Operadora maliciosa injeta créditos manuais na agência e nega o ato aproveitando-se de que o sistema não exige segunda aprovação e usa chaves compartilhadas.

Mitigação Proposta: Aplicar controle de dupla aprovação (Maker-Checker / regra dos quatro olhos) e individualizar chaves SSH.

Título: TM-06 Quebra rápida de banco vazado via MD5
Elemento Afetado: PostgreSQL 16 (tm.Store)
Categoria (STRIDE): Information Disclosure
Severidade: Critical
Status: Open

Descrição: Atacante efetua dump das tabelas do banco de dados relacional e reverte senhas de 6 dígitos em poucos segundos usando Rainbow Tables de MD5 obsoleto.

Mitigação Proposta: Migrar o armazenamento de hashes de credenciais para Argon2id ou bcrypt com salt randômico.

Título: TM-09 Repositório Git: Vazamento de chaves (Elevation of Privilege)
Elemento Afetado: Arquivo .env (tm.Store)
Categoria (STRIDE): Elevation of Privilege
Severidade: Critical
Status: Open

Descrição: Atacante lê commits antigos do Git e extrai arquivos .env com senhas de produção que foram deletados no commit atual mas persistiram na árvore do Git.

Mitigação Proposta: Executar purga completa do histórico do repositório usando BFG/Git-Filter-Repo e rotacionar as chaves.

Título: TM-08 Segredos vazados em texto claro (Logs)
Elemento Afetado: Arquivo .env (tm.Store)
Categoria (STRIDE): Information Disclosure
Severidade: High
Status: Open

Descrição: Ator malicioso (interno ou via invasão) acessa os arquivos de log ou o CloudWatch e copia credenciais, tokens JWT e dados cadastrais gravados sem máscara.

Mitigação Proposta: Implementar interceptadores de log para mascarar e ofuscar dados sensíveis e segredos de autenticação.

Título: TM-16 Extração de documentos em S3 público
Elemento Afetado: Bucket S3 KYC (tm.Store)
Categoria (STRIDE): Information Disclosure

Severidade: High
Status: Open

Descrição: Quadrilha Laranja descobre leitura pública no S3, extrai milhares de selfies/documentos legítimos e os usa para fraudar aberturas de contas em outras instituições.

Mitigação Proposta: Bloquear acesso público ao S3. A aplicação deve gerar URLs pré-assinadas (Pre-Signed URLs) de curta duração.

Título: EXEMPLO — Interceptação de credenciais no tráfego interno
Elemento Afetado: F2 Credenciais (tm.Flow)
Categoria (STRIDE): Information Disclosure
Severidade: Medium
Status: Open

Descrição: EXEMPLO DIDÁTICO (apague ou mantenha): o Nginx encerra o TLS e repassa CPF+senha ao auth-service em HTTP claro na rede Docker. Um contêiner comprometido na mesma rede pode capturar credenciais.

Mitigação Proposta: mTLS entre serviços / service mesh; segmentar redes Docker por serviço.

Título: TM-07 Captura massiva de chaves Pix por URLs
Elemento Afetado: Ordem Pix + JWT (tm.Flow)
Categoria (STRIDE): Information Disclosure
Severidade: Medium
Status: Open

Descrição: Atacante roda script sequencial nas URLs públicas de compartilhamento de comprovantes clonando nomes, CPFs e valores de transferências sem autenticação.

Mitigação Proposta: Exigir token JWT do usuário para abrir recibos ou gerar chaves públicas com UUID pseudo-randômico de dose única.

Título: TM-10 Injeção de saldo falso via rede interna lateral
Elemento Afetado: Ajuste Manual Saldo (tm.Flow)
Categoria (STRIDE): Tampering
Severidade: Critical
Status: Open

Descrição: Atacante compromete microsserviço menor na rede Docker interna e chama o endpoint HTTP sem autenticação do ledger para inflar saldos e desviar ativos.

Mitigação Proposta: Implementar arquitetura Zero-Trust exigindo autenticação mTLS interna e assinatura digital entre serviços.